



Data Protection

Diego López, CISSP, CISM

CRYPTOGRAPHY

Cryptography is the discipline that studies the principles and methods used to secure information by transforming data in ways that prevent unauthorized access or modification. It provides multiple security services including confidentiality, integrity, authentication, and non-repudiation.

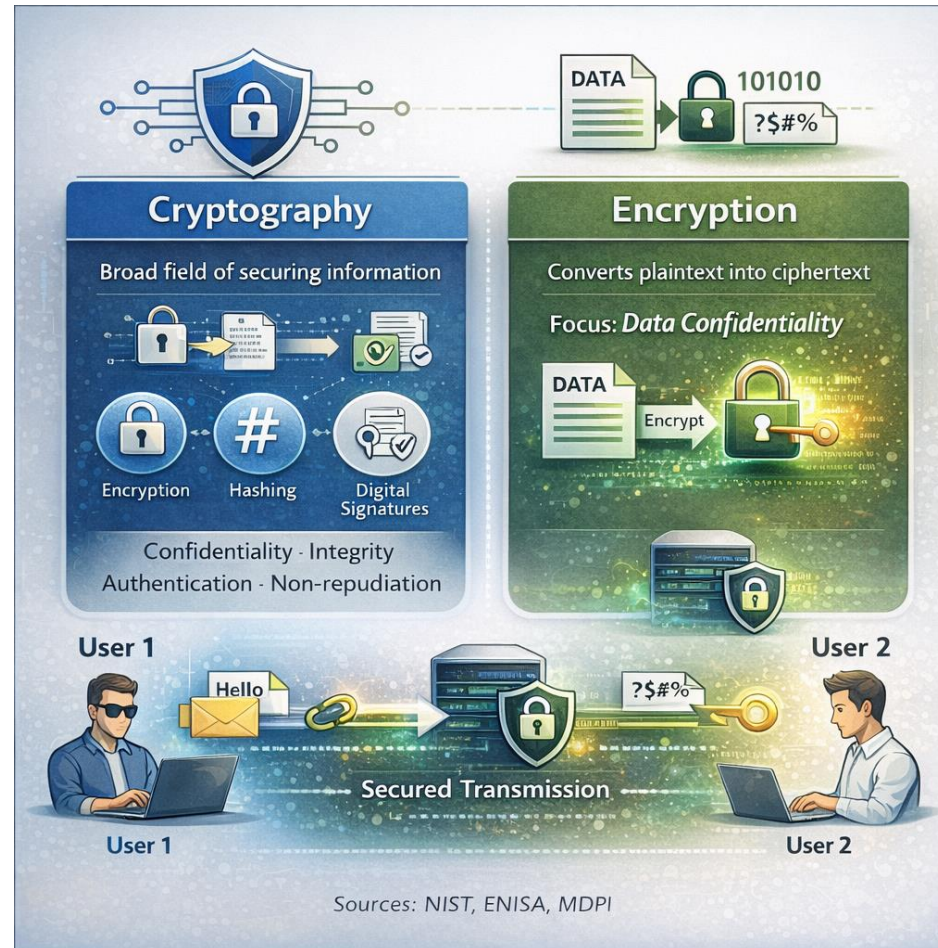
ENCRYPTION

Encryption is a specific cryptographic technique that converts readable data (plaintext) into an unreadable format (ciphertext) to protect the confidentiality of information. Only authorized users with the correct cryptographic key can decrypt and recover the original data.

SO, WHAT IS THE DIFFERENCE ?

CRYPTOGRAPHY

Cryptography is the broader field that includes multiple mechanisms such as encryption, hashing, and digital signatures, while encryption is a specific method within cryptography focused on protecting data confidentiality.



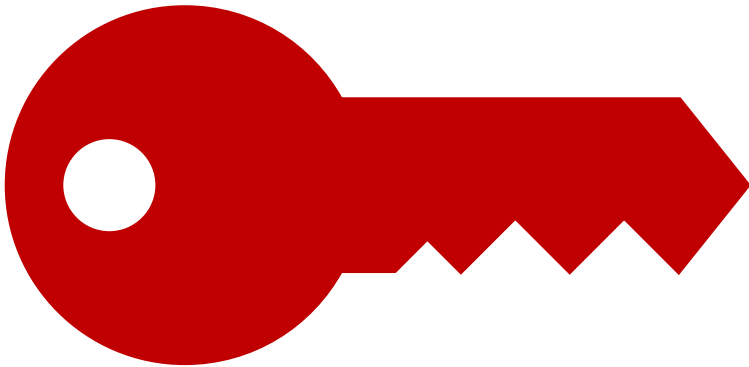
Criptografía	Criptanálisis	Esteganografía
Estudio y práctica de técnicas para transformar información legible en formas inaccesibles a terceros. Objetivo: • Confidencialidad • Integridad • Autenticación • No repudio.	Disciplina dedicada a atacar y evaluar sistemas criptográficos: busca vulnerabilidades, recupera claves o textos originales mediante métodos matemáticos, estadísticos o de ingeniería.	Técnicas para ocultar la existencia de un mensaje dentro de un soporte (imagen, audio, fichero). Complementa la criptografía cuando es importante que nadie sospeche la comunicación.

HISTORIA DE LA CRIPTOGRAFÍA

La **Criptografía** tiene sus orígenes en la antigüedad, cuando las civilizaciones necesitaban proteger mensajes militares y políticos.



EJEMPLO DE CRİPTOGRAFÍA



Mensaje original:

- HOLA

Cifrado César (desplazamiento 3):

- KROD

Solo quien conoce la clave (3) puede descifrarlo correctamente.

HISTORIA DEL CRIPTOANÁLISIS

El Criptoanálisis surge casi al mismo tiempo que la criptografía, porque siempre que alguien crea un sistema para ocultar información, otro intenta romperlo.

- **Mundo árabe (siglo IX)**

El matemático Al-Kindi desarrolló el **análisis de frecuencias**, método que permitía romper cifrados de sustitución estudiando la frecuencia de las letras.

Este fue uno de los primeros enfoques científicos para romper códigos.

- **Segunda Guerra Mundial**

El desciframiento de la máquina **Enigma** es uno de los casos más famosos de criptoanálisis.

El trabajo de Alan Turing ayudó a acortar la guerra.

- **Era moderna**

Actualmente, el criptoanálisis se basa en:

- Matemáticas avanzadas
- Teoría de números
- Probabilidad
- Ataques computacionales

También se estudian vulnerabilidades en algoritmos actuales para mejorar la seguridad.



EJEMPLO DE CRIPTOANÁLISIS

Si interceptamos este mensaje cifrado:

- KHOOR

Y notamos que la letra “O” se repite mucho, podemos sospechar que corresponde a la “L” (una letra frecuente en español).

Probando desplazamientos, descubrimos que es un cifrado César con desplazamiento 3:

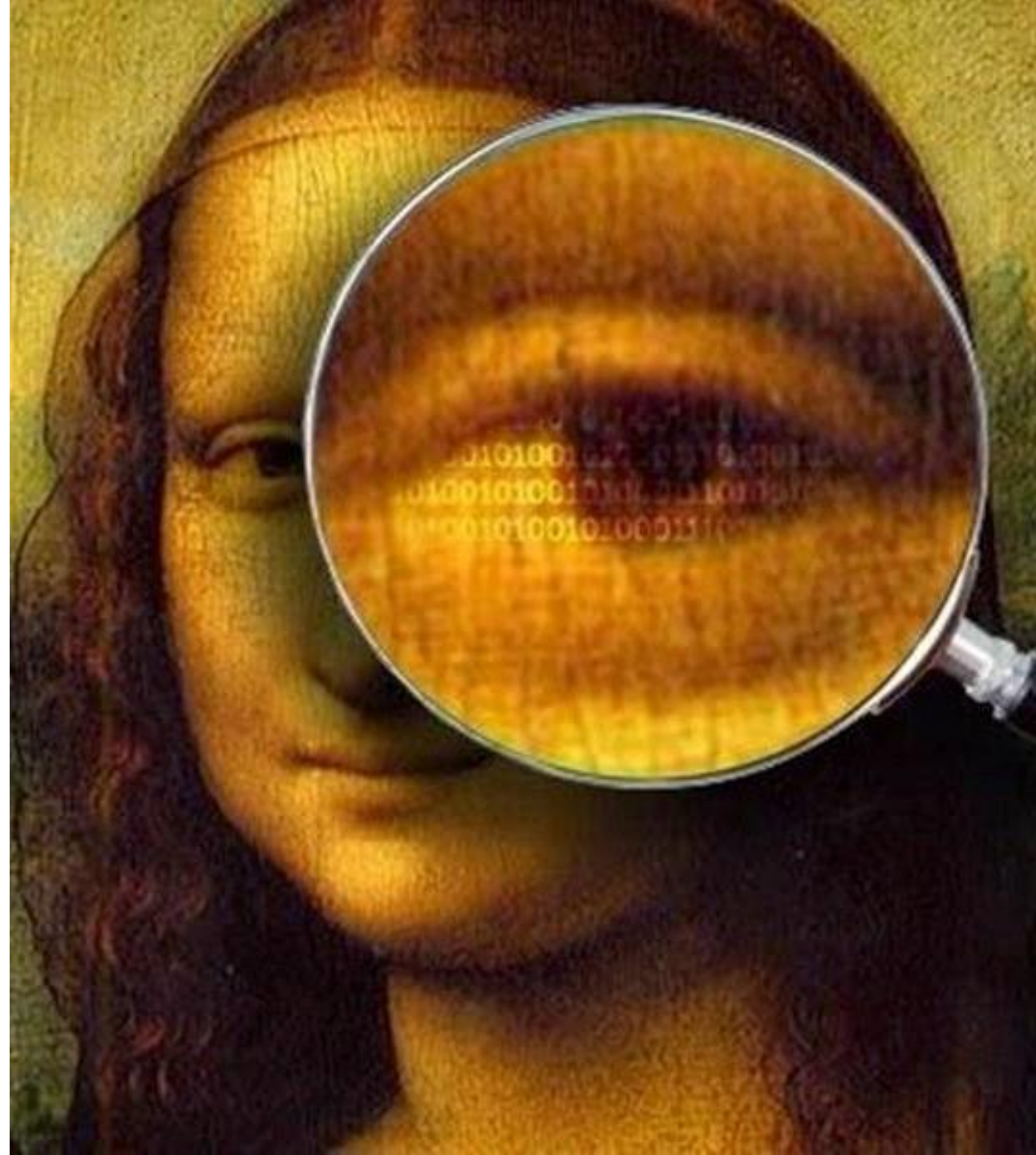
- HELLO

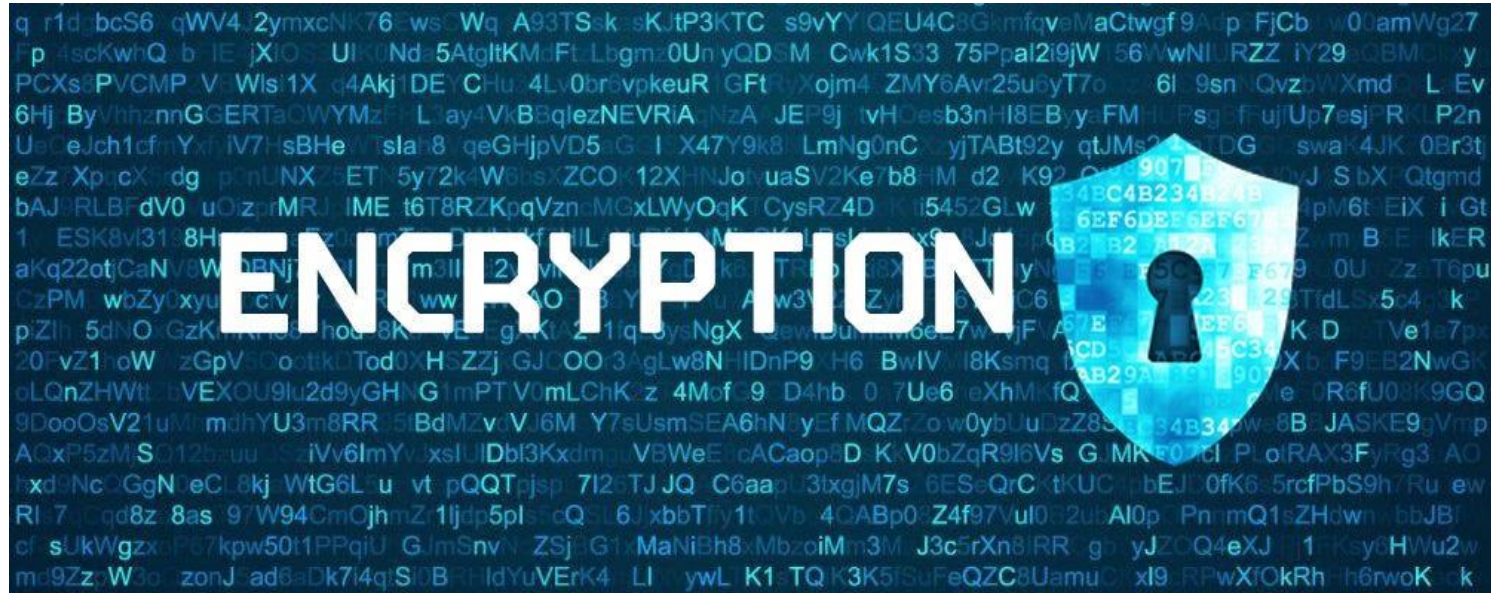
Se logró romper el código sin conocer la clave inicialmente.



EJEMPLO DE ESTEGANOGRAFÍA

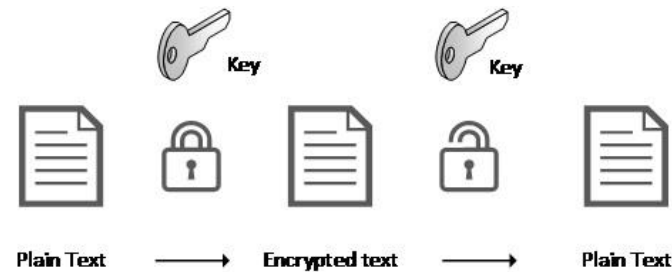
- Una imagen puede contener un mensaje oculto modificando los bits menos significativos de cada píxel.
- Visualmente la imagen se ve igual, pero internamente contiene información secreta.





ENCRYPTING DATA

When encrypting data, you start with some plaintext information. You then take that information and use an encryption algorithm in combination with an encryption key to encrypt the data. The algorithm is the mathematical formula for the encryption, a cryptographic key is a binary value used by an algorithm to control the transformation between plaintext and ciphertext.



```

Chapter 18 — vi plaintext.txt — 58x11
Encryption protects information from prying eyes by making
it unreadable to anyone who does not have the required de
cryption key. We use encryption to protect data that is a
t rest on a storage device or in motion over a network.
~
~
~
~
  
```

FIGURE 18.1 A plaintext message

```

Chapter 18 — vi ciphertext.txt — 58x11
69E26EAE650B3DF894A95206D7DC8752D803A38412D8144E49CD50ECF
4BFF4172DCF5F294786279BEEE5082098F308436122C6481681443A87B
7BD61F397CD5CAE73A91B6B750C64A7C46FC05266662045F003237AE12
3CB977AEFC770ABB9476756D9D070874F7DF0947E9B535259974168078
840F73C54D53D6AA77D88C73CC81510A8573E4D3FFDA2EE4735F981876
4E4598FAE2FAC4F9307B3033B221DAF2A63803672DCE4F1DB401E2C649
D13D995FFADE7FB8B15658FC82962AB38867F205C62826F0D44D9EA6C6
BA58834CB947807A5AB87EFE14F9FD3C4BD9AAEA1B8A71E811109422E9
E36C333C69260456
  
```

FIGURE 18.2 The ciphertext message obtained by encrypting the plain text in Figure 18.1

ENCRYPTION ALGORITHMS - SYMMETRIC ENCRYPTION

There are many different kinds of encryption algorithms, and there are different ways to categorize them. Two of the major categories of encryption algorithms are symmetric algorithms and asymmetric algorithms

Symmetric Encryption

In symmetric encryption algorithms, also known as shared secret encryption algorithms, the encryption and decryption operations use the same key. If one user encrypts a message using the secret key “Apple,” a second user would have to decrypt the message with that same key. It’s a shared secret. You can think of a shared secret key as the password to a message.



FIGURE 18.4 Symmetric encryption with two individuals

ENCRYPTION ALGORITHMS - SYMMETRIC ENCRYPTION

If three people are involved, things change a little bit. Alice and Bob can still use their shared secret to communicate with each other privately, but now Charlie joins the picture and wants to be able to communicate with Alice or Bob, as shown in Figure 18.5. Each person in the group wants the ability to communicate privately with any other member of the group.

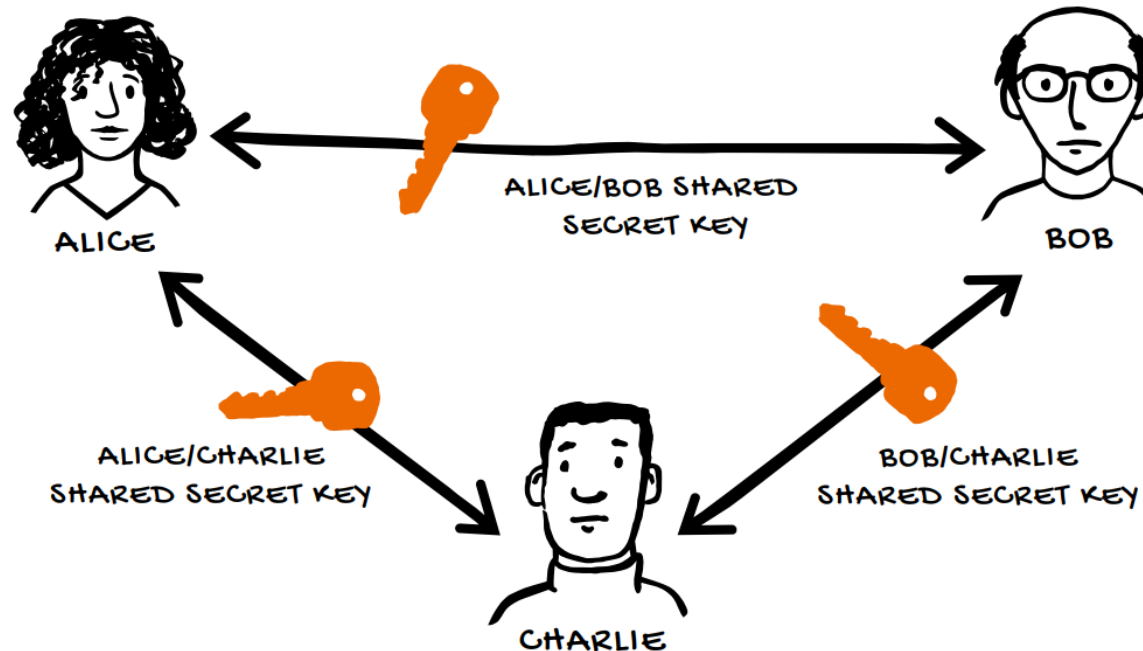


FIGURE 18.5 Symmetric encryption with three individuals

ENCRYPTION ALGORITHMS - SYMMETRIC ENCRYPTION

Alice has a way to communicate with Bob, but a second key is needed that allows her to communicate privately with Charlie. However, there is still a missing link. Bob and Charlie need a third key to communicate with each other. So, in order for these three people to communicate, three keys are required.

As groups get larger, more and more keys are required to facilitate the communication. There's a formula that computes the number of keys required for symmetric cryptography.

Where n is the number of people who want to communicate, the number of keys required, k , is equal to:

$$n(n-1) \div 2$$



ENCRYPTION ALGORITHMS - SYMMETRIC ENCRYPTION

As you can see in Figure 18.6, when larger groups are involved, symmetric cryptography starts to require an unmanageable number of keys. For example, an organization with 10,000 employees would need almost 50 million encryption keys! If a new person were to join the organization, the organization would need to generate 10,000 new keys for that person to communicate with other employees—and then distribute those 10,000 keys to every other employee in the organization!

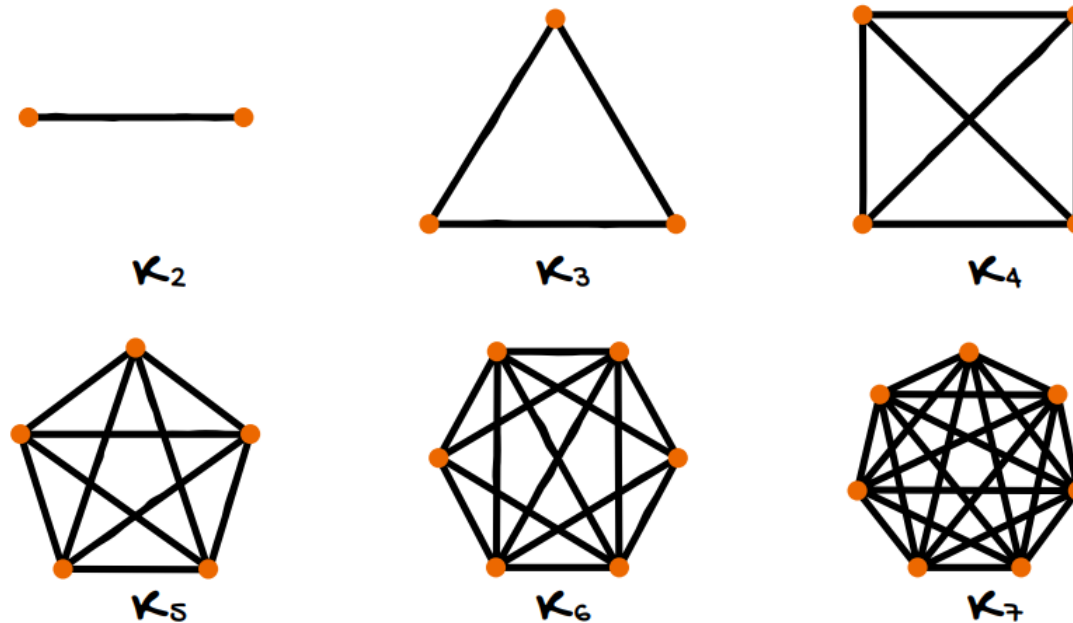


FIGURE 18.6 Symmetric encryption with larger groups

ENCRYPTION ALGORITHMS - SYMMETRIC ENCRYPTION

Symmetric encryption involves two main types of symmetric ciphers: **block ciphers** and **stream ciphers**.

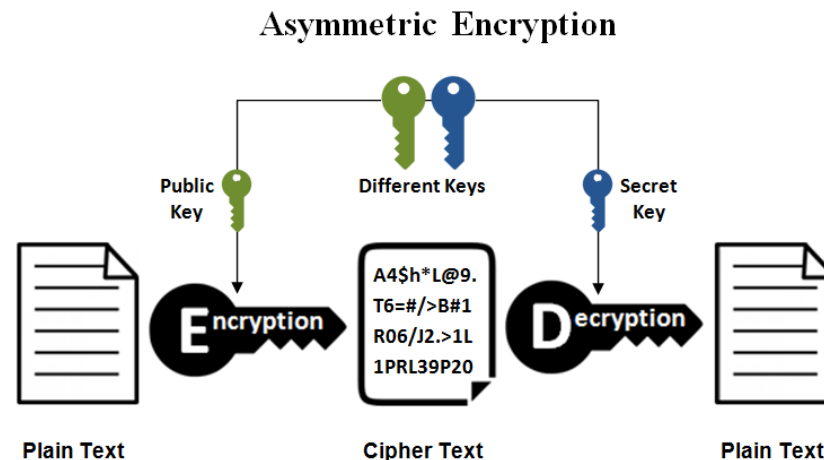
- Block ciphers, such as Advanced Encryption Standard (AES), encrypt data in fixed-size blocks.
- Stream ciphers, like RC4, encrypt data one bit or byte at a time, making them suitable for real-time data processing.
 - ✓ Data Encryption Standard (DES) and Triple DES (3DES)
 - ✓ Advanced Encryption Standard (AES)
 - ✓ Twofish
 - ✓ Blowfish

ENCRYPTION ALGORITHMS - SYMMETRIC ENCRYPTION

Asymmetric cryptography solves the problem of scaling to large groups by using the concept of key pairs. Each user gets two keys:

- A public key that they can freely distribute to anyone they want to communicate with
- A private key that they keep secret

In asymmetric cryptography, anything that is encrypted with one key from the pair can be decrypted with the other key from that pair. For normal communications, the sender of the message would encrypt it with the recipient's public key, which is publicly known. The recipient would then use their private key to decrypt the message.



USES OF ENCRYPTION

Encryption is used in two different environments: to protect data at rest and to protect data in transit.

Data at Rest

Data at rest is simply stored data. You can encrypt individual files, entire disks, or the contents of a mobile device. If someone gains access to one of those encrypted files, disks, or mobile devices, you don't need to worry about the encrypted data because they won't have access to the decryption key.

Full-disk encryption (FDE) is a technology built into some operating systems that automatically encrypts all of the data stored on a device. FDE technology is particularly useful for laptops, tablets, smartphones, and other devices that might be lost or stolen. Someone who steals the device will not be able to access the data it contains if that data is protected by full-disk encryption.

USES OF ENCRYPTION

Encryption is used in two different environments: to protect data at rest and to protect data in transit.

Data in Transit

Data in transit is data that's moving over a network. You can protect this data as well by using encryption.

When you access a website using the standard HTTP protocol, that data is unencrypted, and anyone who observes your network activity can eavesdrop on your web use. However, if you use the secure HTTPS protocol, that connection is encrypted, and the data being sent over the network is safe from prying eyes.

You can use the same encryption technology to protect the data being sent in email messages, from mobile applications to their servers, or even protect entire network connections with encryption using a virtual private network (VPN).

HASH FUNCTIONS

Hash function is a one-way function that consistently transforms a variable-length input into a unique, fixed-length output.

- ▶ Hash functions are one-way functions. That means you can't reverse the process of hashing. If you have content, you can use a hash function to calculate the hash value of that content, but you can't go the other way around.
- ▶ Hash functions map variable-length input to fixed-length outputs. That simply means that you can send input of any length to a hash function and the hashes that it produces will always be the same length.
- ▶ Hash functions also produce unique output. That means that you should not be able to find two different inputs that produce the same hash value as output.
- ▶ Hash functions are repeatable in that you always get the same output from hashing the same input using the same hash function.

HASH FUNCTIONS

In order for a hash function to be effective, it must meet all four of those criteria. A hash function can fail in one of the following two ways:

- ▶ First, if the hash function is reversible, it is not secure. Hash values can become public, so you don't want any way for someone seeing the hash value to determine the content of a message.
- ▶ The more common way that a hash function will fail is that someone will demonstrate that it is not collision-resistant. That means that it doesn't achieve the "unique output" part of the definition and it is possible to find two inputs that produce the same hash output. If that were the case, it would make it possible to forge digital signatures and digital certificates. That's clearly undesirable!

MD5

Ron Rivest created the Message Digest 5 (MD5) hash function in 1991. That's the same Rivest who coined the RSA encryption algorithm. MD5 was the fifth in a series of hash functions that became more and more secure. MD5 replaced the MD4 algorithm after research showed that MD4 was insecure.

MD5 produces a 128-bit hash. Over the years, cryptanalysts discovered a series of flaws in the MD5 algorithm that chipped away at its collision resistance. In 2013, three cryptanalysts discovered a technique that breaks MD5's collision resistance in less than a second on a store-bought computer. Therefore, MD5 is no longer considered secure and should not be used. However, many systems still rely on MD5 for secure applications—a very bad idea!

HASH FUNCTIONS

SHA

The Secure Hash Algorithm (SHA) is another series of hash functions approved by the National Institute of Standards and Technology (NIST) for use in federal computing applications.

The first version of SHA, SHA-1, produces a 160-bit hash value. Cryptanalysts have discovered increasingly severe flaws in SHA-1 over the past few years and no longer consider SHA-1 secure for use.

SHA-2 replaced SHA-1 and is actually a family of six different hash algorithms. The different algorithms of SHA-2 have different hash lengths, which include 224-, 256-, 384-, and 512-bit hashes.

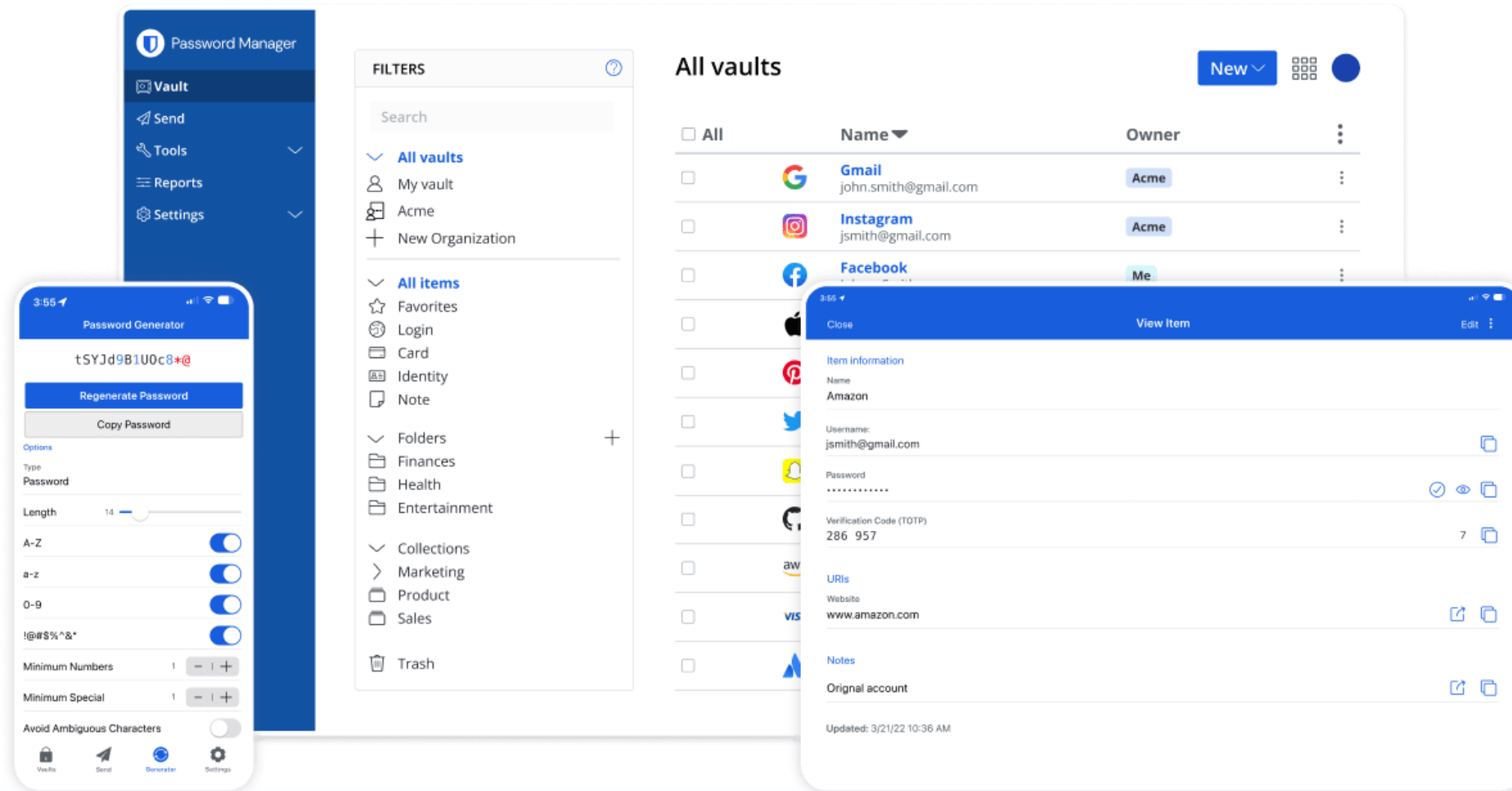
All of the SHA-2 algorithms are mathematically similar to SHA-1 and MD5 and are theoretically susceptible to the same flaws that broke those algorithms. Some attacks now exist against certain configurations of SHA-2, but the algorithm is still widely used.

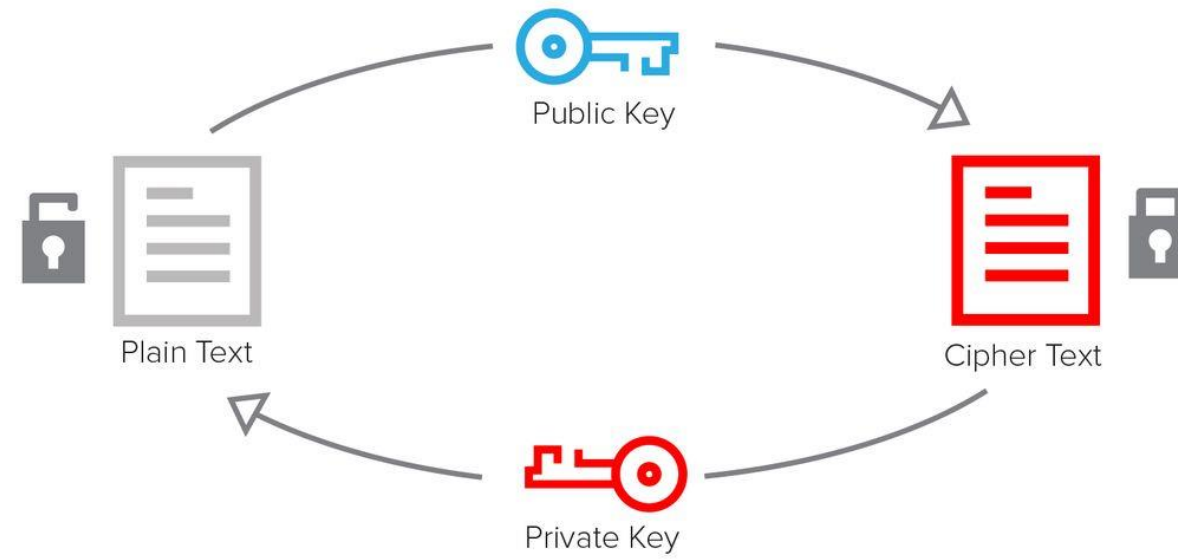
NIST recognized that the mathematical similarity between SHA-2 and other, insecure, algorithms represents a future risk to SHA-2 and, thinking ahead, they began a competition to select a third version of SHA, SHA-3, in 2007. In 2012, NIST announced the selection of the Keccak algorithm as the SHA-3 standard.

EXAM ESSENTIALS

- ▶ Encryption is the process of transforming plaintext information into ciphertext that can't be read by unauthorized individuals. Decryption uses a decryption key to convert ciphertext back into plain text.
- ▶ Encryption can be used to protect data at rest by encrypting individual files or folders. Full-disk encryption (FDE) uses encryption to protect the entire contents of a device.
- ▶ Encryption can be used to protect data in transit by encrypting it as it travels over a network. The HTTPS protocol encrypts web traffic and is a secure alternative to the unencrypted HTTP protocol. Virtual private networks (VPNs) encrypt entire network connections.
- ▶ Symmetric encryption algorithms, such as AES, use the same key to encrypt and decrypt messages. Asymmetric encryption algorithms, such as RSA, use public and private key pairs.
- ▶ Hash functions are one-way functions that transform a variable-length input into a unique, fixed-length output.

HASH FUNCTIONS





ASYMMETRIC ENCRYPTION

Introduction

Symmetric encryption algorithms use the same key to encrypt and decrypt data. Asymmetric encryption algorithms, on the other hand, use separate keys ? one key is used to encrypt, and another key is used to decrypt.

A common use case of asymmetric encryption is public key exchange.

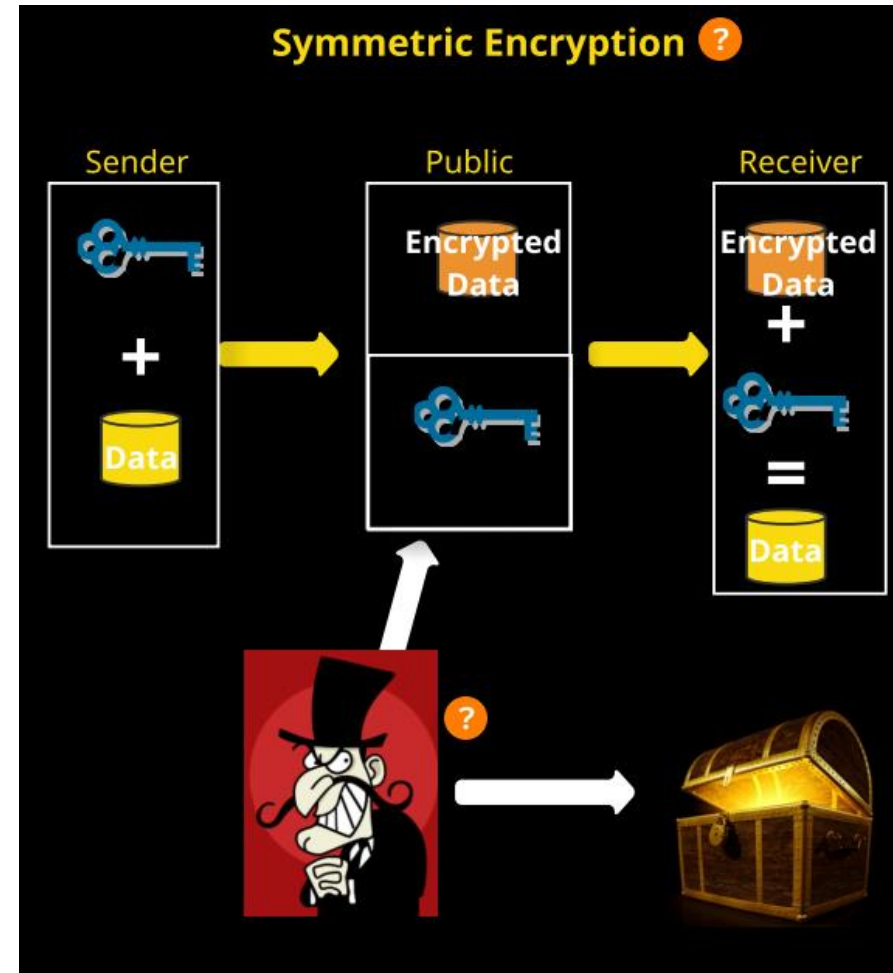
Why Do We Use Asymmetric Encryption?

When we're using symmetric encryption, how do we share the key that we're going to use to facilitate secure communications?

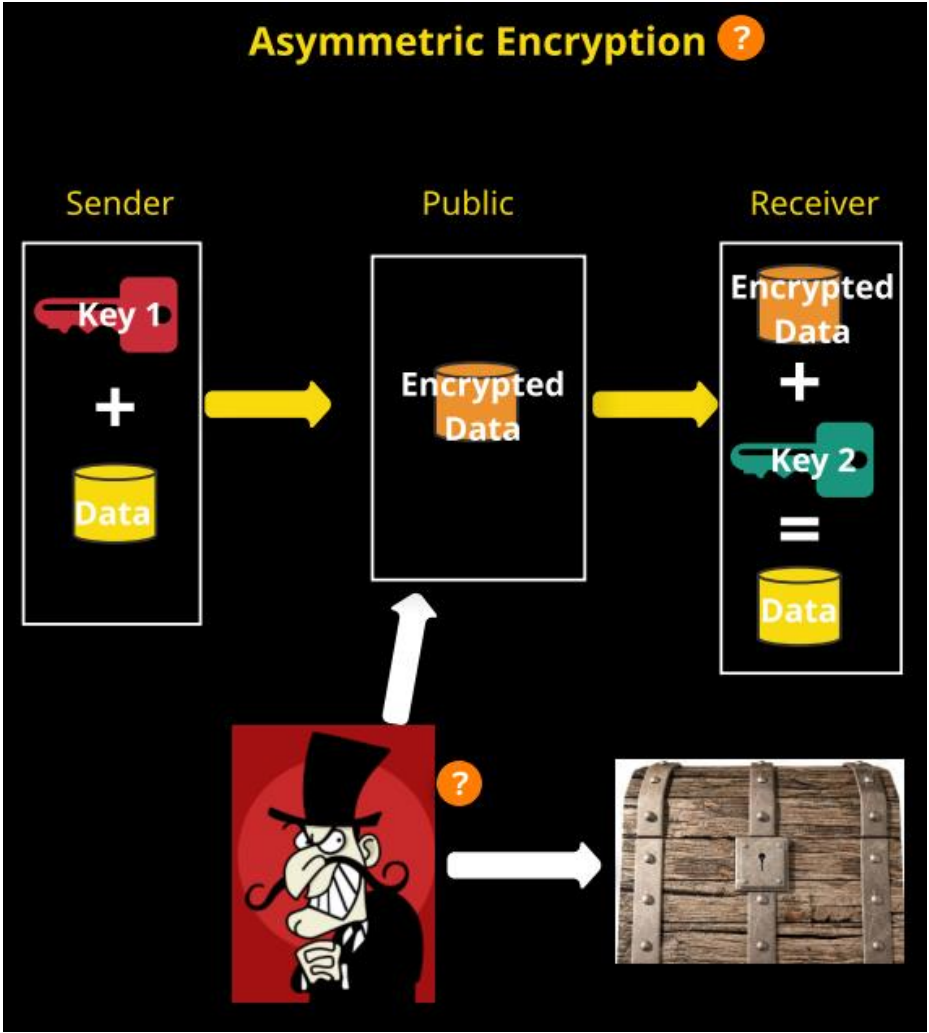
The Problem with Symmetric Encryption

We send the key across a medium, either an intranet or the internet. This gives bad guys a chance to intercept the key and use it to decrypt our data.

PUBLIC KEY EXCHANGE



PUBLIC KEY EXCHANGE





PUBLIC KEY INFRASTRUCTURE

PUBLIC KEY EXCHANGE

PKI Overview

- Asymmetric encryption used for communications
- Not any specific technology, but rather a framework
- Certificates are issued by a **certificate authority (CA)**
- Provides confidentiality, authenticity, integrity and non-repudiation
 - **Confidentiality:** Data is encrypted in transit.
 - **Authenticity:** Digital certificates of sender are required to send the message.
 - **Integrity:** Digital signature tells us that the sender has the appropriate private key.
 - **Non-repudiation:** Both the sender and the receiver are assured of each other's status during communications.

PUBLIC KEY EXCHANGE

PKI Terms

Certificate Authority (CA): A trusted (usually third-party) server that generates, validates, distributes, and revokes digital certificates.

Certificate Revocation List (CRL): A list of certificates that have been revoked before their expiry date.

Certificate Signing Request (CSR): The first step to obtain an SSL certificate for a web server. When we generate keys on our own server to include in the CSR, information about the organization and the server are included that the CA will then use to generate the SSL certificate.

Online Certification Status Protocol (OCSP): Systems can use OCSP to check the status of certificates. OCSP traffic is sent via HTTP , and OCSP servers verify the status of the requested certificate. This allows systems to verify that certificates have not been added to the CRL.

PUBLIC KEY EXCHANGE

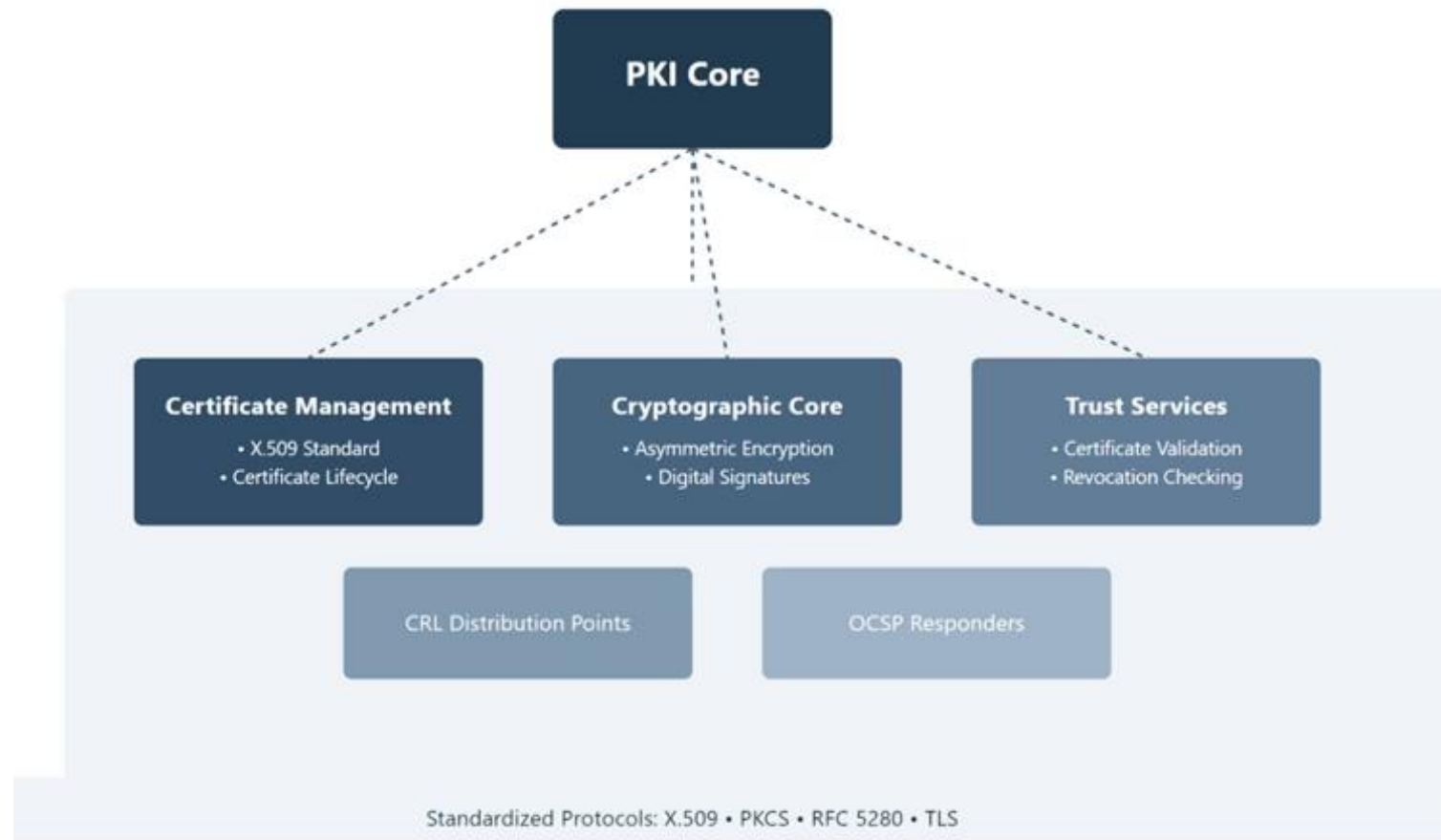
PKI Terms

Pinning: The process of associating a specific public key with a particular web server to prevent the use of forged certificates and reduce the risk of man-in-the-middle attacks.

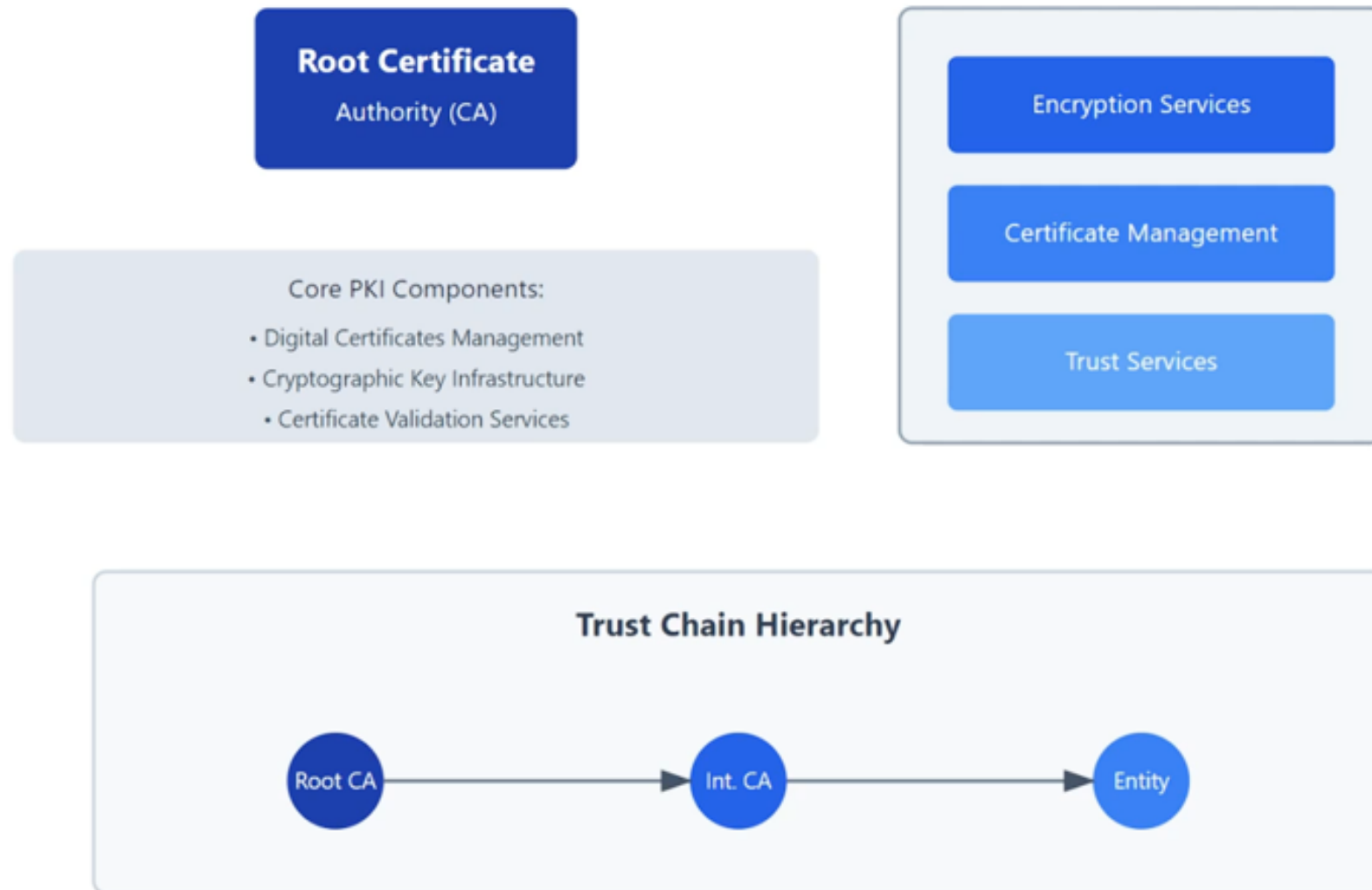
Digital Certificates: Data files used to link an entity with a public key. These are used to verify the identity of the linked entity and also contain information about the issuer of the certificate for verification purposes.

Key Escrow: A key storage arrangement in which an authorized third party is granted access to the keys under certain circumstances. Usually used to restore lost keys.

PUBLIC KEY INFRASTRUCTURE: TECHNICAL ARCHITECTURE



PUBLIC KEY INFRASTRUCTURE (PKI) FOUNDATION

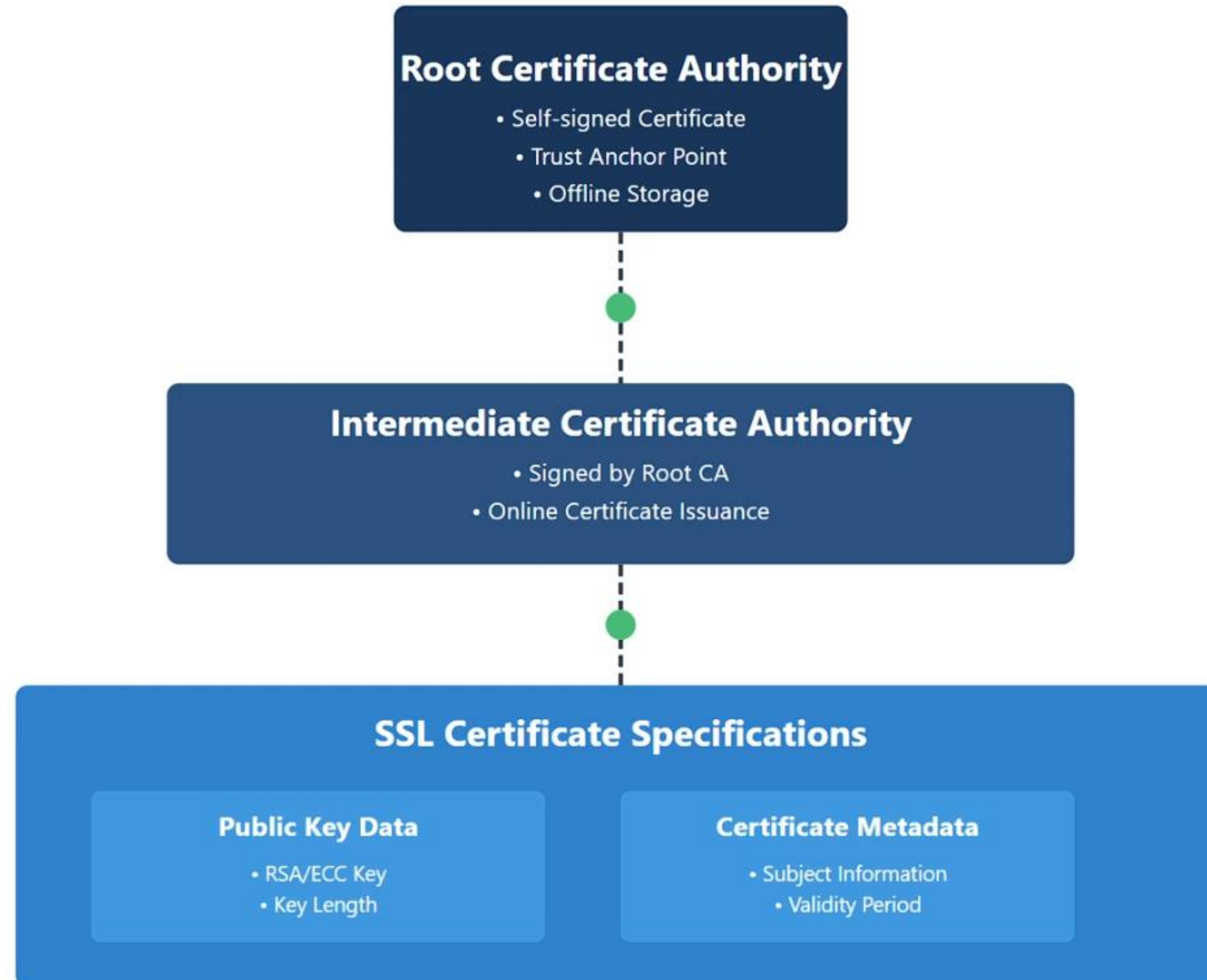


Terms

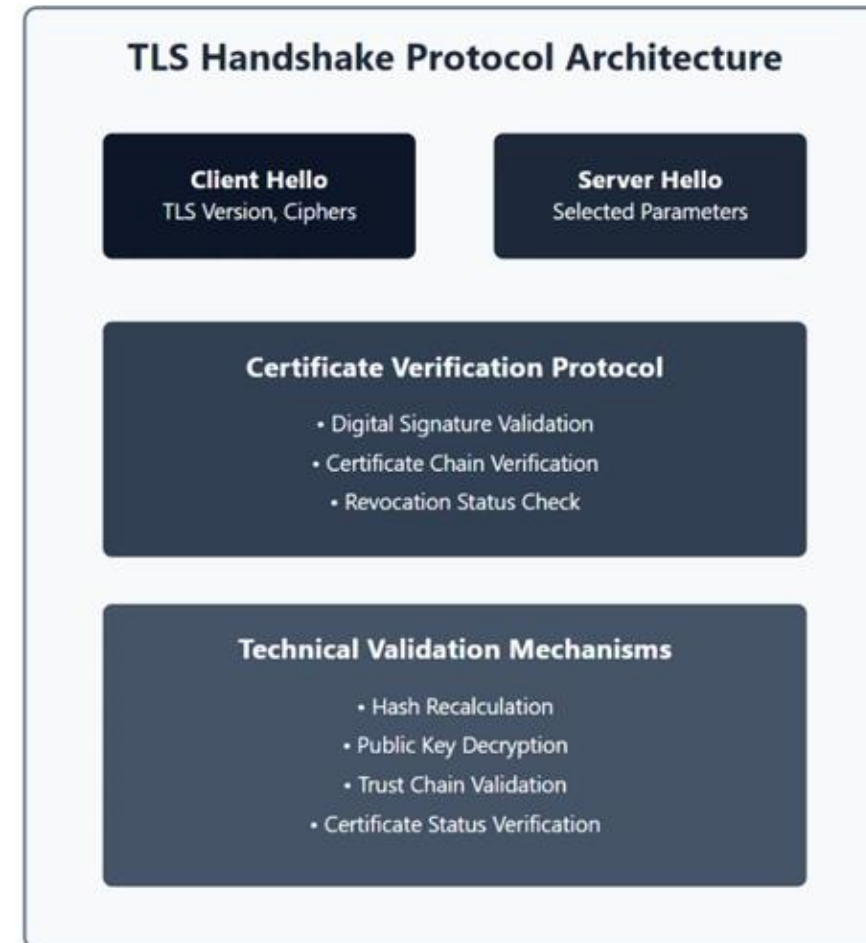
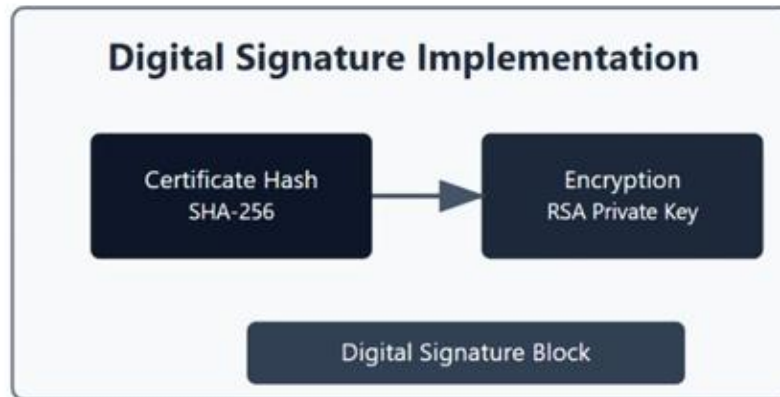
Digital signature: Value computed from a text using a private key, which can be verified with the corresponding public key. This allows confirming that it could only have been generated by the holder of the private key.

Secure Sockets Layer (SSL): Protocol for protecting communications at the transport layer, which provides secure communication services analogous to those offered by the sockets interface.

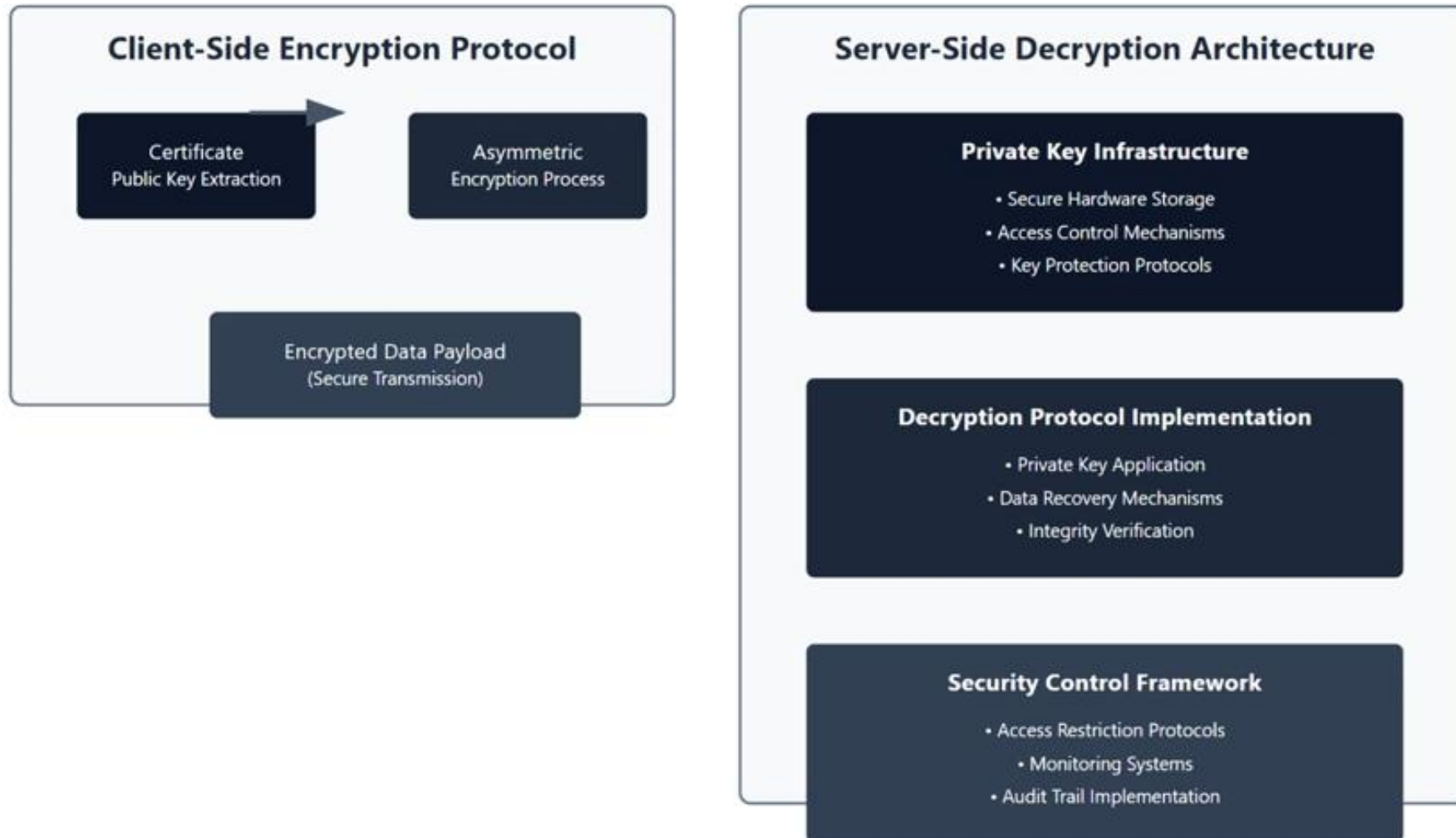
Transport Layer Security (TLS): Security protocol that provides privacy and data integrity for Internet communications. The implementation of TLS is standard practice in the design of secure web applications.



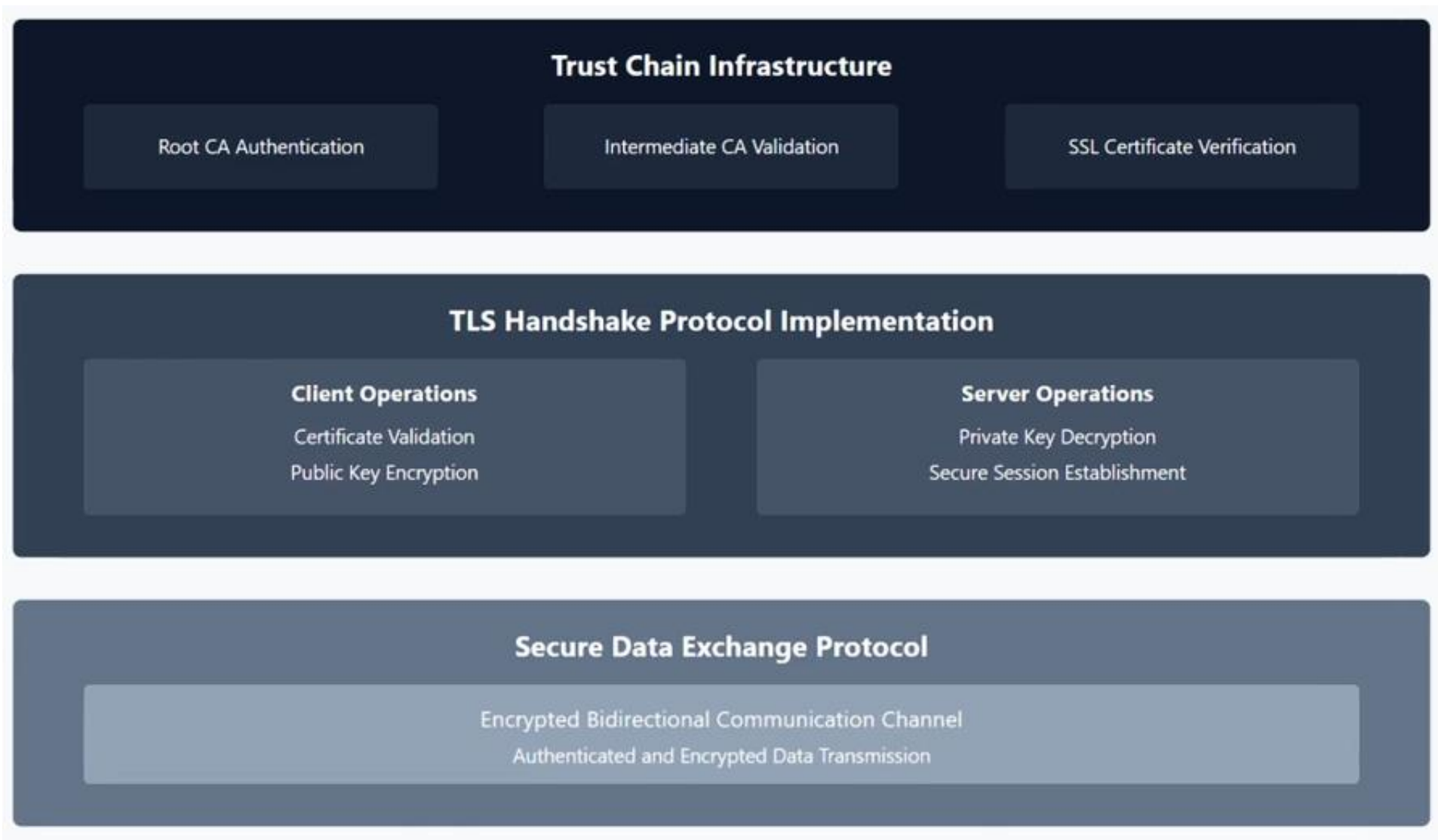
SSL/TLS PROTOCOL: DIGITAL SIGNATURE VERIFICATION ARCHITECTURE



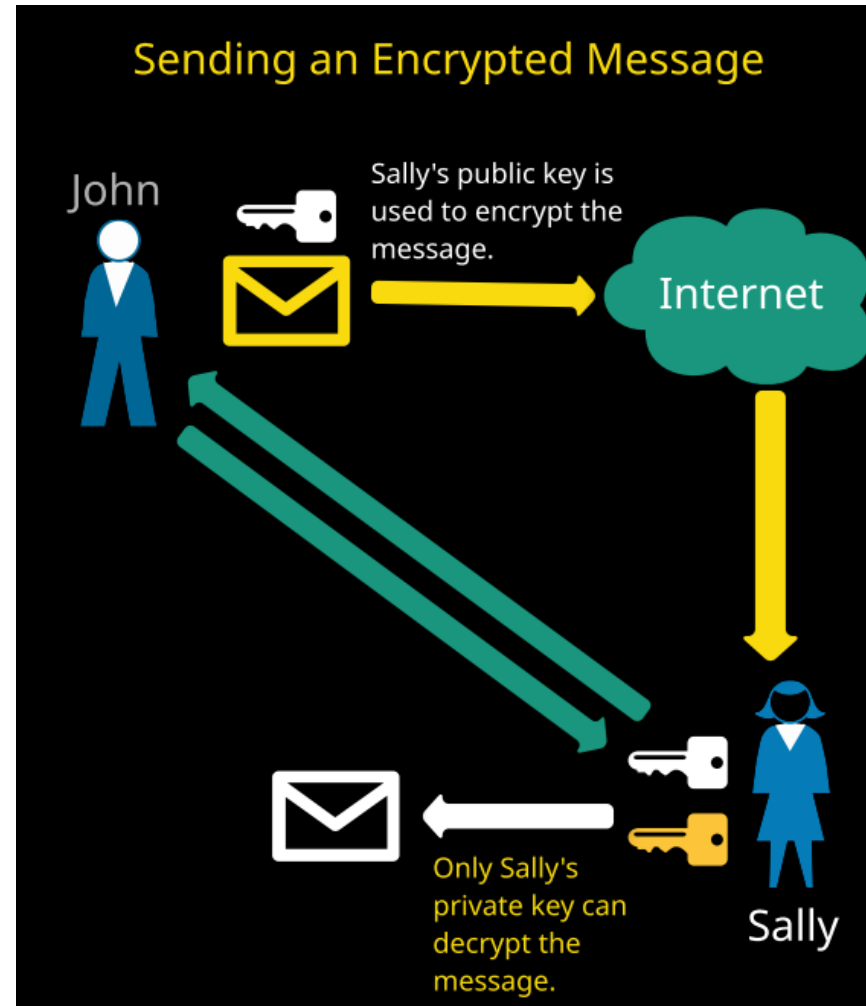
SSL/TLS PROTOCOL: ASYMMETRIC ENCRYPTION ARCHITECTURE



SSL/TLS PROTOCOL: COMPREHENSIVE TECHNICAL ARCHITECTURE



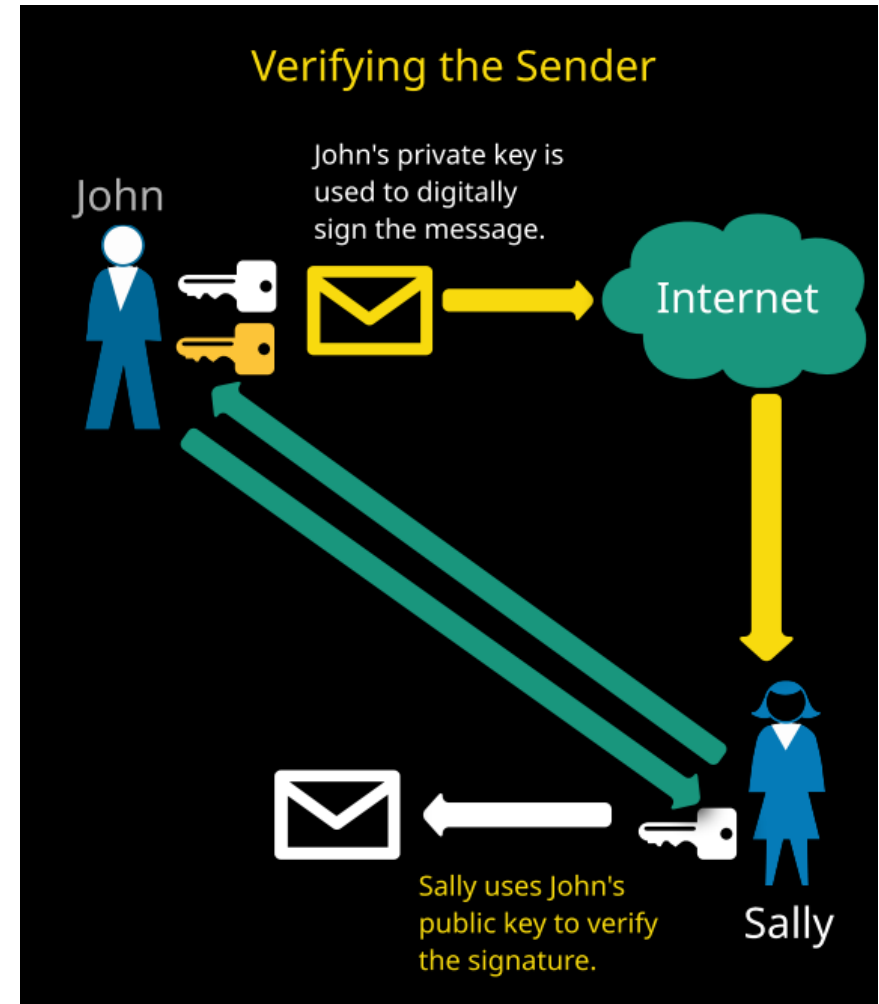
PUBLIC KEY EXCHANGE



- **Confidentiality:** Data is encrypted in transit.

PUBLIC KEY EXCHANGE

- **Authenticity:** Digital certificates of sender are required to send the message.
- **Integrity:** Digital signature tells us that the sender has the appropriate private key.
- **Non-repudiation:** Both the sender and the receiver are assured of each other's status during communications.

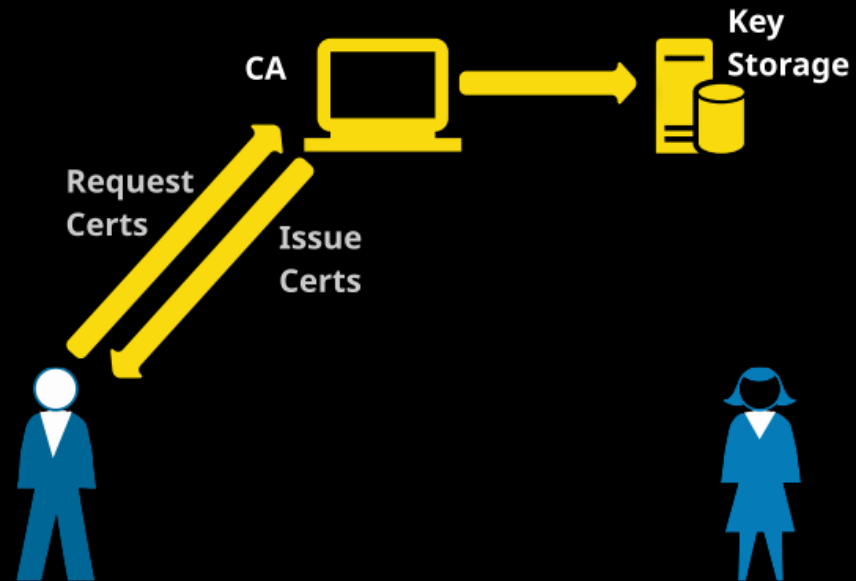


PUBLIC KEY EXCHANGE

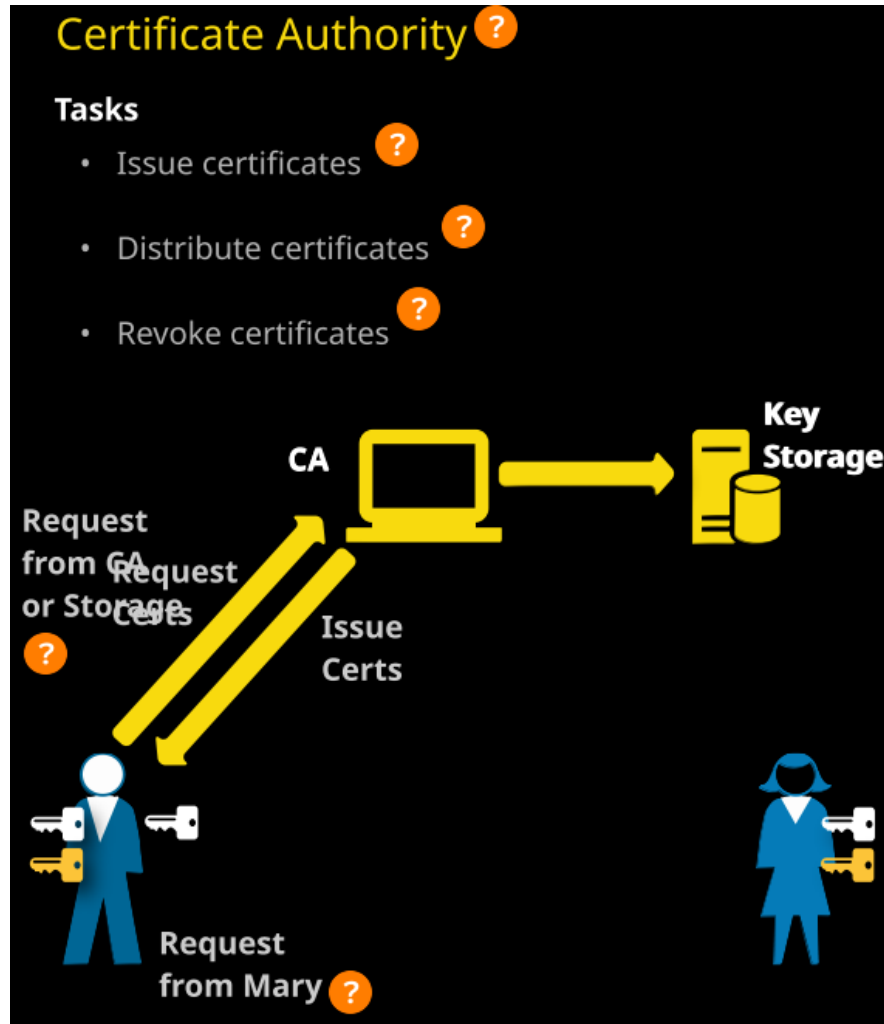
Certificate Authority ?

Tasks

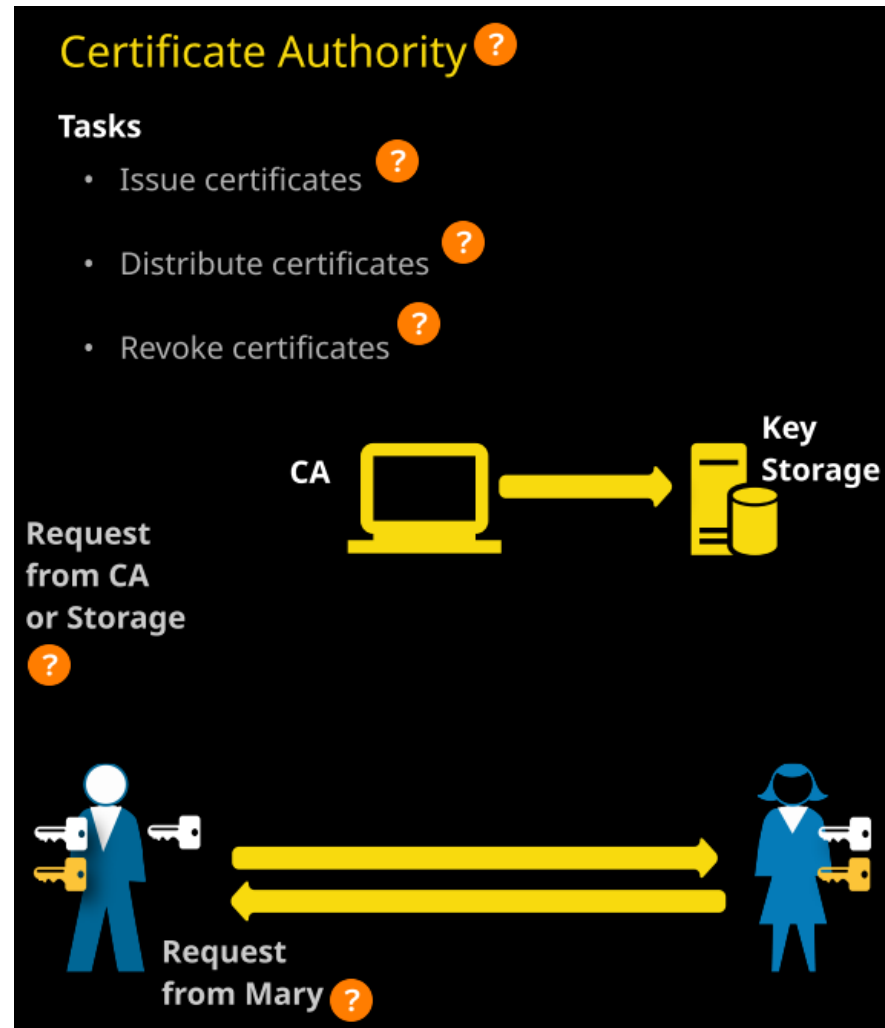
- Issue certificates ?
- Distribute certificates ?
- Revoke certificates ?



PUBLIC KEY EXCHANGE



PUBLIC KEY EXCHANGE

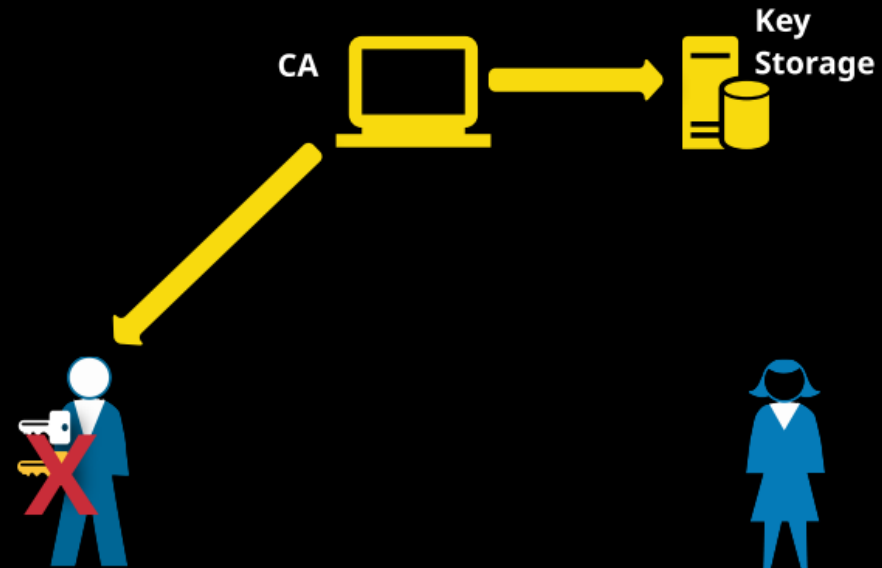


PUBLIC KEY EXCHANGE

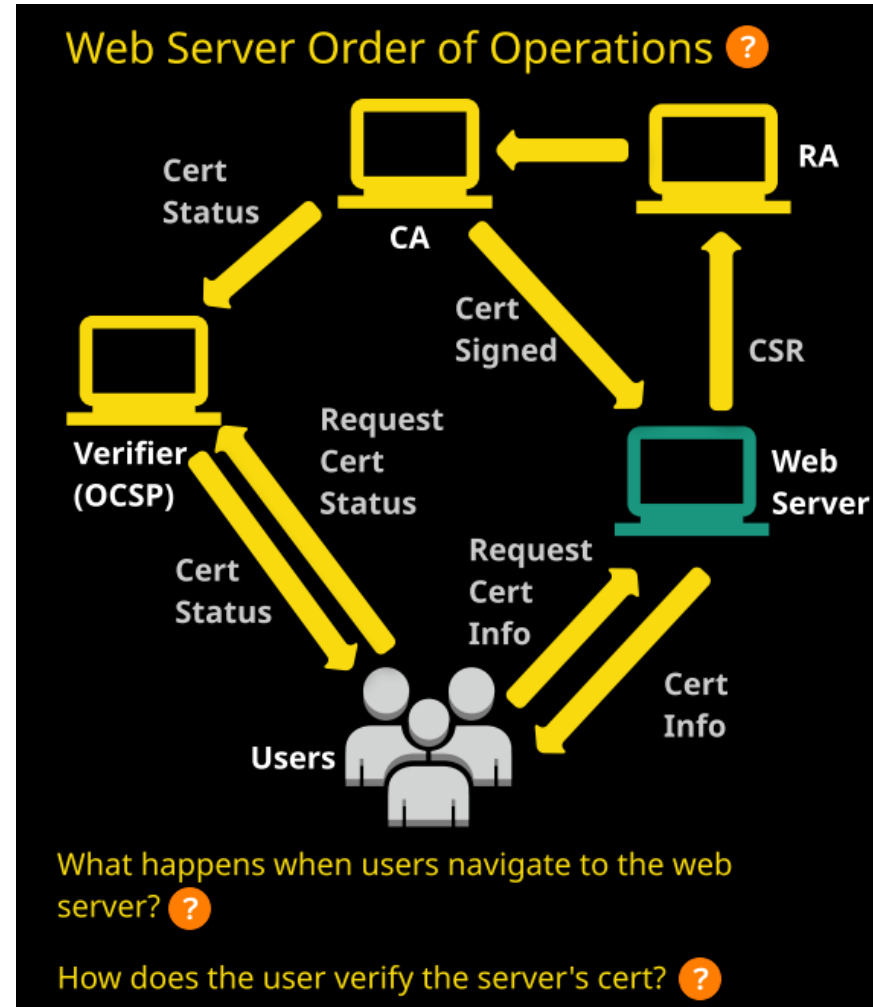
Certificate Authority ?

Tasks

- Issue certificates ?
- Distribute certificates ?
- Revoke certificates ?



PUBLIC KEY EXCHANGE





PUBLIC KEY EXCHANGE

PUBLIC KEY EXCHANGE

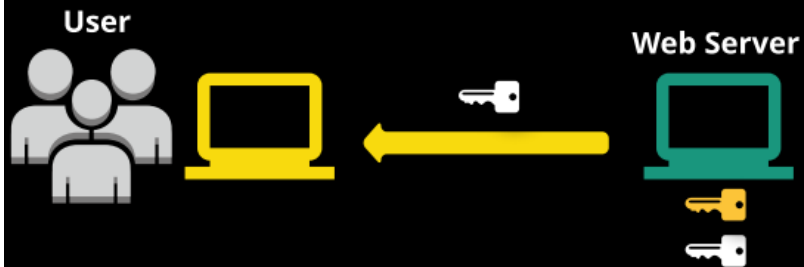
Public Key Exchange

To find out how a public key exchange works, let's talk about how SSL/TLS connections are established.

Step 1: ?

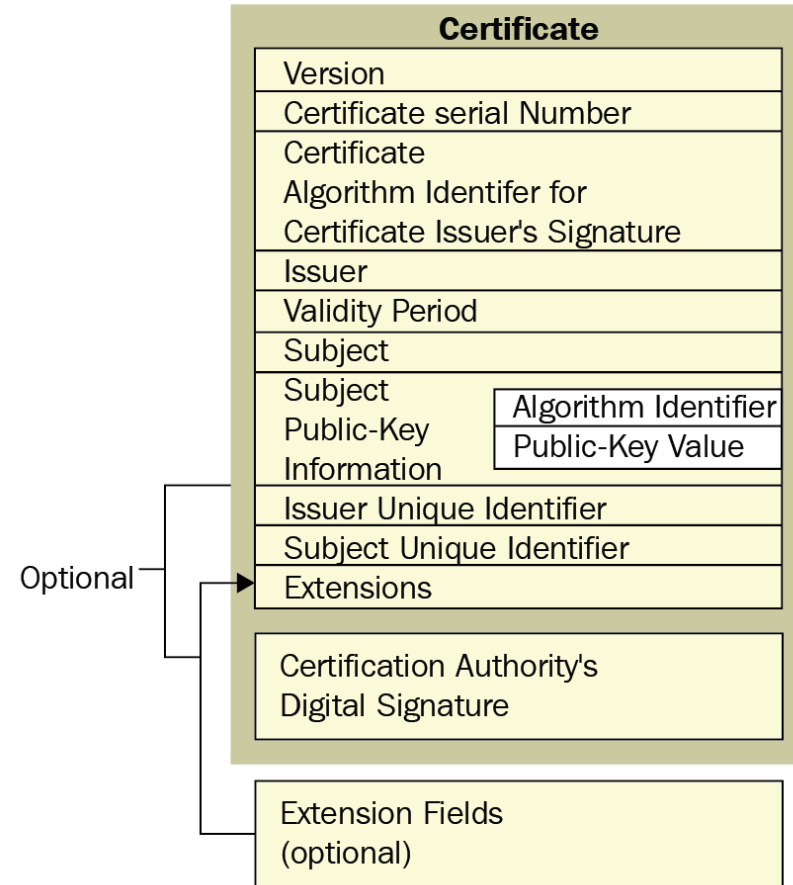


Step 2: ?



PUBLIC KEY EXCHANGE

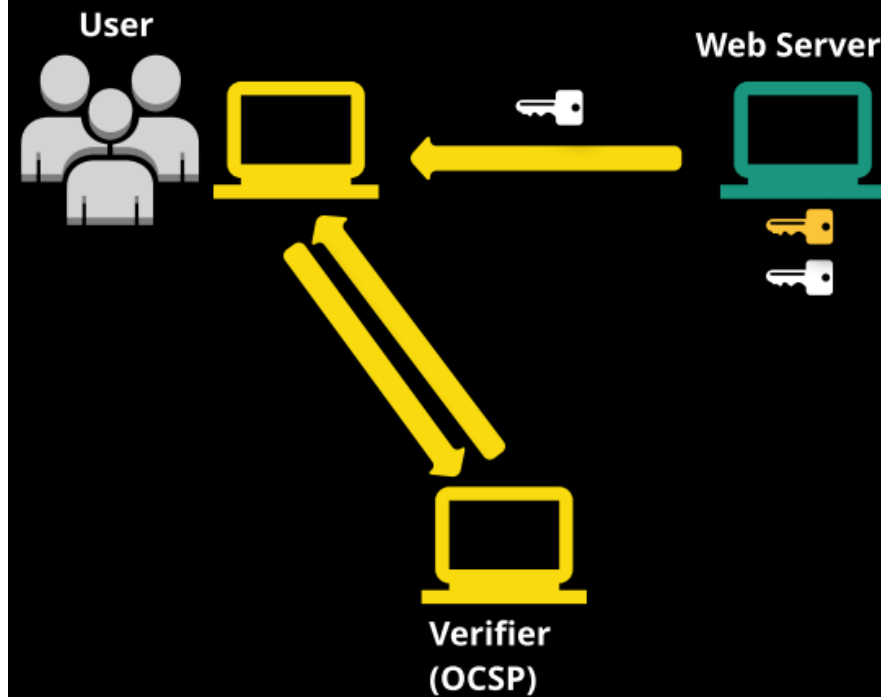
Standard X.509 certificate format



PUBLIC KEY EXCHANGE

Public Key Exchange

Step 2A: ?



PUBLIC KEY EXCHANGE

Public Key Exchange

Now that you (the user) have the server's public key, you can send encrypted data to the server. But what if the server needs to send data to you?

Step 3: ?



A symmetric session key is created by the user, encrypted with the server's public key, and sent back to the server.

PUBLIC KEY EXCHANGE

Public Key Exchange

The results:

Asymmetric Key Exchange

Symmetric Data Exchange



Gracias